

Number One Travel & Tourism Stages 11, 12 and 12.1

نمبرون للسفر و السياحة — تقرير المراحل ١١ و ١٢ و ١٢.١

Booking experience · Customer account · Production integrations

Report date: 17 September 2026 · Branch `claude/awesome-feynman-zyfjar` · Head `87c0a73`

Stage 11 — BUILT + VERIFIED

Booking engine on a labelled development supplier adapter. Commit `635cc7c`, 16 Sep 2026.

Stage 12 — BUILT + VERIFIED

Customer account ecosystem on labelled development identity and data adapters. Commit `10a92cc`, 17 Sep 2026.

Stage 12.1 — PARTIALLY COMPLETE

Production adapters implemented and browser-verified against a contract test server; no external service connected. Commit `87c0a73`, 17 Sep 2026.

Scope of this report: what was built in each stage, how it was verified, what was found and fixed, what remains and what the business must supply. Every figure comes from the repository at the head commit and from the test runs recorded in this document. Nothing here claims production readiness for a service that is not connected.

Live preview: <https://mashhorfoods.github.io/mashhor-demo/> (GitHub Pages build 284, successful).

1. Executive summary

Three stages were delivered on top of the verified Stage 10 foundation without redesigning it. Stage 11 turned the booking entry into a complete booking engine: search, results with transparent recommendations, compare, flight details, family traveller forms, extras, review with re-quoting, payment behind a provider boundary, and an honest confirmation. Stage 12 added the customer account: sign in and sign up, a dashboard, trips with a unified trip view, bookings, travellers, documents, payments, notifications, support and settings, with booking continuity and supervisor attribution preserved through authentication. Stage 12.1 connected that account to production-capable services through the adapter architecture: a documented backend contract, an HTTP client with cookie sessions and CSRF, production adapters for identity, customer data, document storage, payment history, notifications and legal documents, a deploy-time public configuration with a generator that refuses unsafe production builds, and an integration suite that verifies all of it in a real browser against a contract test server.

The programme's data rule held throughout: no prices, dates, partners, contacts, ratings, legal text or credentials were invented. Every dynamic surface runs on adapters that are clearly labelled as development stand-ins on screen, and a production build cannot fall back to them.

Measure	Stage 11	Stage 12	Stage 12.1
Status	BUILT + VERIFIED	BUILT + VERIFIED	PARTIALLY COMPLETE (no external service connected)
New routes	7 (search + 6 booking steps)	14 (auth 5, account 8, trips 1)	2 (legal/terms, legal/privacy)
New modules	assets/js/booking/ 20 files, 1,786 lines; 21-journey.css	assets/js/account/ , 22-account.css	config, API client, diagnostics, 4 adapters, legal seam; assets/js/account/ now 22 files, 1,798 lines
Automated checks	tests/journey.mjs : 512	tests/account.mjs : 782	tests/integration.mjs : 518 (+ contract server)
Full gate at head	18 suites green · links 0 problems · language audit 0 untranslated across 51 pages · accessibility audit 0 findings · 0 console errors		

2. Stage 11 — Booking experience / booking engine

2.1 What was built

The journey from the Stage 10.9 booking context to a confirmed booking, with one context system and one journey record in the session, and a strict separation of screens, booking domain and supplier adapters. Every screen that shows supplier or payment data carries a visible development-data notice.

Area	Delivered
Routes	search/ , booking/details/ , booking/travellers/ , booking/extras/ , booking/review/ , booking/payment/ , booking/confirmation/ — all noindex, bilingual, on the shared header, footer and phone navigation.
Domain	Journey record with per-step guards and recovery states; search request building for round trip, one way and multi-city; a replaceable location registry with a reusable airport/city combobox (also used by the booking entry); ranking with printed, data-driven reasons (cheapest, fastest, fewest stops, family, balanced); price breakdown; traveller fields and validation per type and service; payment provider registry; adapter contract with a development flights adapter and a request-mode fallback for services without inventory.
Results	Search summary with edit; "help me choose" priorities; sort; filters as a panel on desktop and a sheet on phones; compare up to three on price, duration, stops, departure, arrival, baggage and fare rules; loading skeletons, empty, error, expired, unknown-place and filtered-empty states.
Details → confirmation	Segments, layovers, baggage, fare and change/cancel rules, price breakdown and one CTA; one form per traveller with age checks at the travel date and a draft that survives a language switch; included and optional extras with a live total; review with re-quote, price-change and unavailable handling; payment with processing feedback, retry, another method or back to review; confirmation with reference and status that never claims a ticket was issued.
Attribution	The supervisor from the entry link is carried through every step to the confirmation. No commission logic, no supervisor surface.

2.2 Verification

- ✓ 512 automated checks: search building and invalid inputs; results states, filters, sort, priorities, compare; family composition and passenger validation; review total against the pricing module; price change; unavailable flight; payment processing, failure, retry and booking failure after payment; confirmation; request-mode services; back navigation, refresh and session recovery; 390/834/1440 in Arabic and English with no overflow, one h1, at most one dominant action and labelled controls.
- ✓ Browser matrix at three widths in both languages with zero console errors; every earlier suite green; language audit 0 untranslated; accessibility audit 0 findings.

2.3 Found and fixed during verification

- The flights adapter was never registered, so every service fell into request mode — an installed-adapters module now registers it.
- Pending combobox searches could reopen the list after Escape or blur; closing now cancels them.
- Passport numbers rejected digits; the payment page could be reached again after a booking (guards now send earlier steps to the confirmation); confirmation copy claimed an email had been sent and referred to an account area; progress steps and detail reasons overflowed at 390px; twelve stray screenshot files were tracked in the repository root.

Stage 11 — results at 1440px, Arabic: summary, priorities, filters panel, labelled offers with printed reasons.

Stage 11 — review at 1440px, English: trip, travellers, price breakdown, contact, supervisor, terms.

3. Stage 12 — Customer account

3.1 What was built

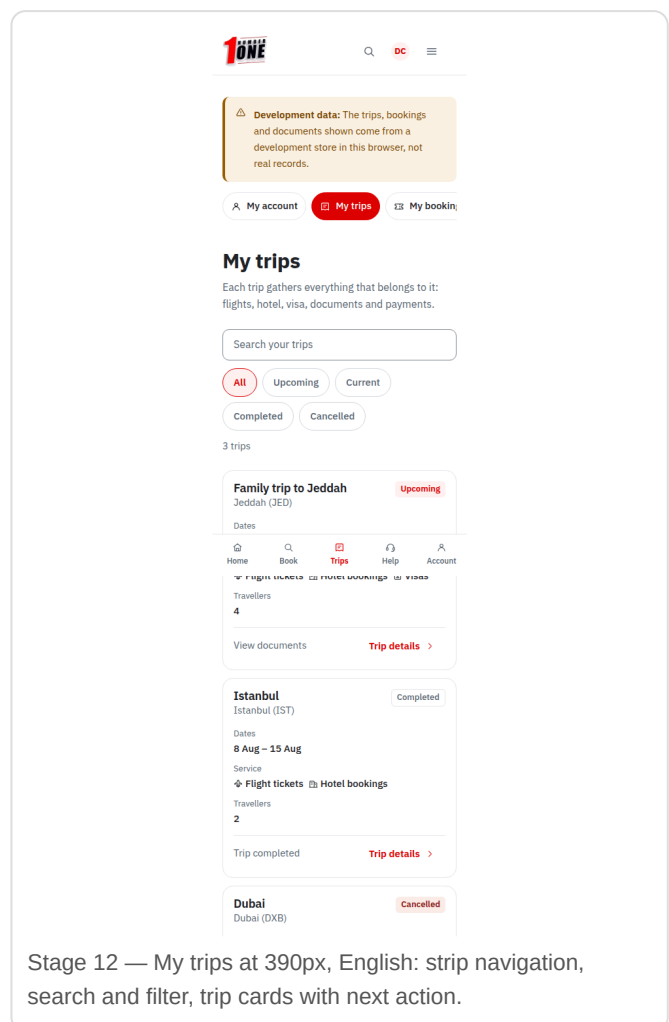
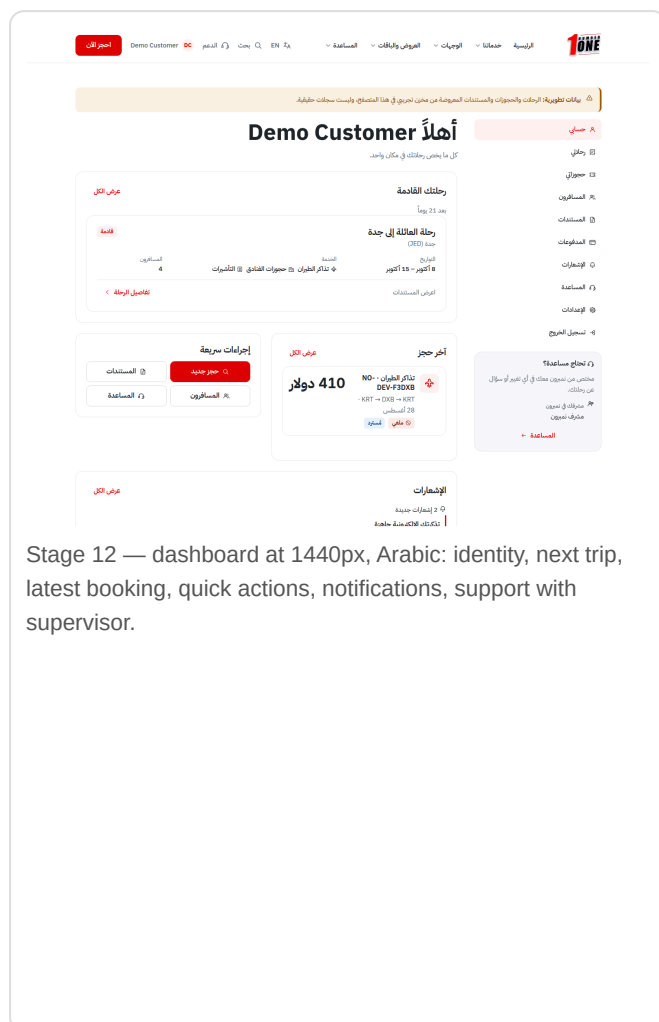
Area	Delivered
Authentication	Sign in, sign up, sign out, forgot password and reset under <code>account/</code> , on a clearly labelled development identity adapter (accounts in the browser, salted digest, 12-hour tokens, single-use reset links, neutral answers, a one-click development customer). The header derives its session from the provider on every load.
Account	Dashboard (identity, next trip with countdown, latest booking, quick actions, unread notifications, support entry); My trips with search and status filter; unified trip details with every service of the trip, its documents, payments, supervisor and support; bookings and booking details; travellers with add, edit, delete and masked passports, picked in the booking form; documents that the system issued, pending ones shown as not issued; payment history with no card data; notifications with read state and mark all; support with verified channels only; settings with profile, language, password and sign out.
Navigation	The customer menu (حسابي, رحلاتي, حجوزاتي, المسافرين, المستندات, المدفوعات, الإشعارات), تسجيل الخروج (المساعدة, الإعدادات); a sidebar on desktop, a scrolling strip on phones and tablets; private routes disallowed in robots and noindex.
Continuity and attribution	Sign-in and sign-up accept a validated in-site return path and resume the journey step with search, selection, typed draft, locale and attribution intact. At the confirmation a signed-in customer's booking is attached to the account once and becomes a trip; a guest is invited to keep it. The supervisor from the entry link is carried to the customer record and cannot be edited.
Authorization	Every data call carries the session token; the adapter answers only from that customer's records; another customer's ids resolve to not found.

3.2 Verification

- ✓ 782 automated checks: invalid credentials, session state and expiry, reset links single-use and non-enumerating, auth outage; cross-customer access by URL and via the facade; guests blocked on every account page; trips, bookings, documents, payments, notifications, support, settings; traveller validation and the booking picker; continuity and attribution; 390/834/1440 in both languages; dialog focus handling.
- ✓ Full gate green; language audit 0 untranslated across 49 pages; accessibility audit 0 findings; Pages build 283 successful.

3.3 Found and fixed

- Service names rendered empty because the registry field is `title`; the account navigation strip widened the page at 834px; back links pointed forward in English; a `route` import was missing on the payment-failure path; a style-guide sample linked to a trip route that no longer exists.



4. Stage 12.1 — Production integrations

4.1 What was built

The account was connected to production-capable services through the adapter architecture. The browser talks to one origin, the customer backend, which fronts the hosted identity provider, the database, document storage, the payment layer and notification delivery, and holds every secret.

Piece	Delivered
Public configuration	<code>assets/js/data/env.js</code> generated at deploy by <code>tools/write-env.mjs</code> from the variables in <code>.env.example</code> (<code>NO_ENVIRONMENT</code> , <code>AUTH_PROVIDER</code> , <code>AUTH_PUBLIC_CONFIG</code> , <code>API_BASE_URL</code> , <code>DOCUMENT_SERVICE_CONFIG</code> , <code>PAYMENT_API_CONFIG</code> , <code>NOTIFICATION_CONFIG</code> , <code>LEGAL_DOCUMENT_CONFIG</code> , <code>DIAGNOSTICS_CONFIG</code>). The generator refuses a production file that uses the development adapter, lacks an https backend or contains a secret-looking value. A production build without a backend registers not-connected adapters and never development data.
HTTP client and diagnostics	<code>core/api.js</code> : cookie sessions (credentials included), CSRF header from the readable double-submit cookie, timeouts, customer-safe error codes (401, 403, 404, 409, 410, 413, 415, 422, 429, 5xx, timeout, network, not configured). <code>core/diagnostics.js</code> : scrubbed technical events with an optional beacon; never passwords, tokens, cookies, card or personal data.
Adapters	<code>session-api-auth</code> (sign up, sign in, sign out, session, refresh, reset, change password); <code>api-customer</code> (profile, trips, bookings, travellers, documents with upload, signed expiring URLs and delete, paged payments, notifications, claim, acceptance); <code>api-legal</code> (Terms and Privacy from the backend or static files); <code>not-connected</code> for production without a backend. The development adapters gained the same capabilities so the screens behave identically.
Screens	Documents: upload dialog with size and type checks, a temporary-link viewer with the expiry shown and a renew action, delete where permitted. Payments: paged history with "show more". Notifications: quiet refresh on focus, no polling. Sign-up: acceptance checkbox with Terms and Privacy links and versions when the documents are published; the versions are recorded with the account. <code>legal/terms/</code> and <code>legal/privacy/</code> render the business's text when supplied and say "not published" otherwise. Every failure maps to a customer-language state with retry and a support path; an unreachable backend during session verification keeps the customer signed in.
Contract and tests	<code>docs/INTEGRATION.md</code> states the backend contract, the environment, the flows, the security requirements and the exact missing inputs. <code>tests/contract-server.mjs</code> is a backend stand-in with HttpOnly cookie sessions, CSRF, per-customer scoping, signed expiring file URLs and fault injection; <code>tests/integration.mjs</code> drives the production adapters against it in a real browser.

4.2 Verification

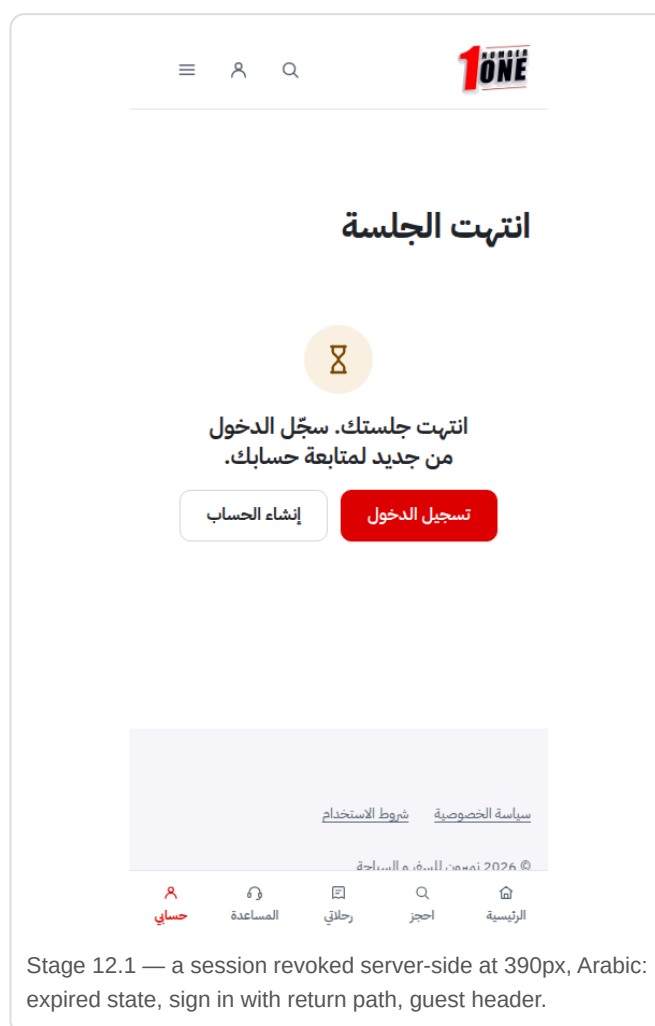
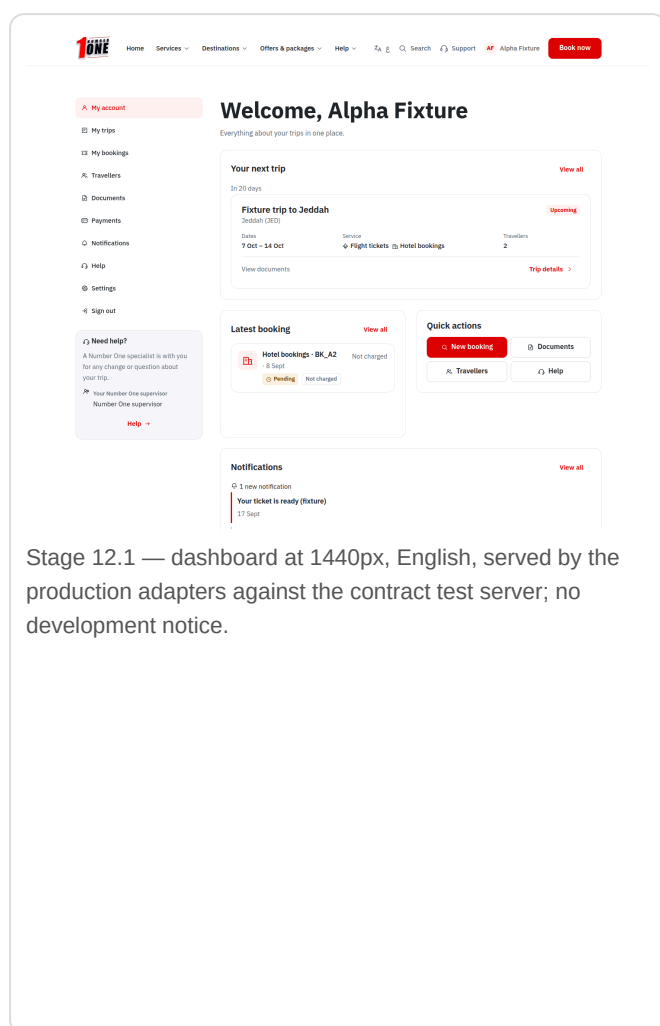
- ✓ 518 integration checks: registry and production gate; authentication including one non-enumerating message, persistence, refresh near expiry, revoked sessions from any 401, sign out ending the server session, duplicate registration, reset links single-use and invalid; authorization across two customers by URL, by direct API call, by marker tampering, CSRF and forged signed URLs; documents upload, authorized and unauthorized retrieval, signed URL expiry and renewal, deleted and revoked documents,

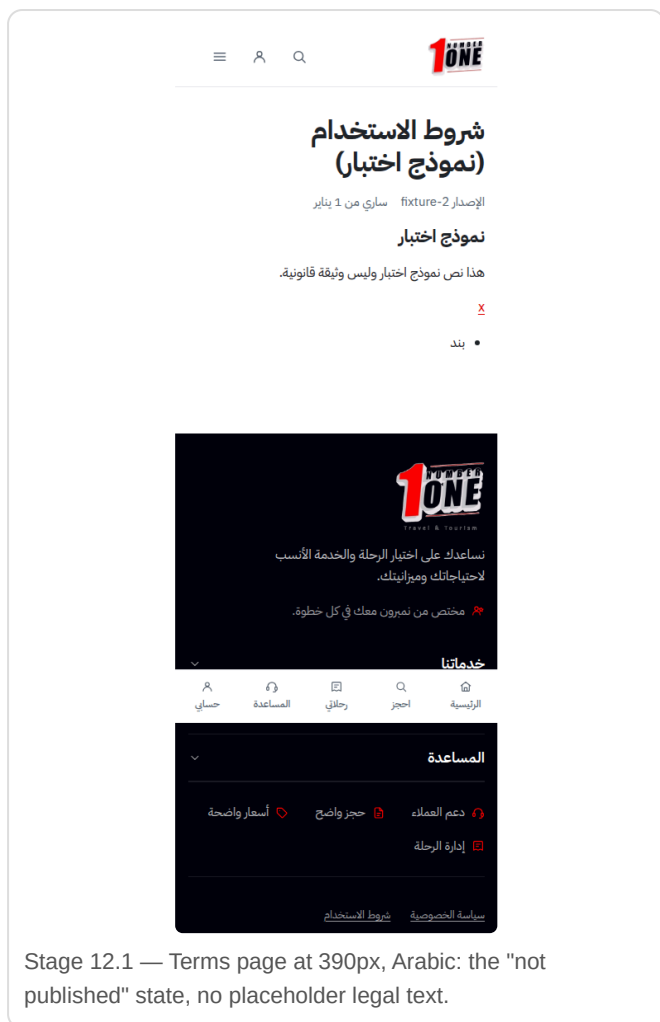
network failure and retry; payments page 1, 429 with the list kept, paging to the end, 503 with retry, empty history; notifications retrieval, read state, timeout and quiet refresh; legal not-supplied and supplied states with scripts stripped, acceptance required and recorded server-side, profile PATCH, travellers through the API; booking continuity and attribution through the backend; network, 5xx, 403 and 429 on the dashboard; diagnostics received and scrubbed; six widths (390, 600, 834, 1024, 1200, 1440) in both languages; keyboard handling of the dialogs.

- ✓ Full gate at head: all suites green, language audit 0 untranslated across 51 pages, accessibility audit 0 findings, Pages build 284 successful.

4.3 Found and fixed

- A red link inside an informational note failed contrast; hidden buttons stayed visible because the button class overrode the hidden attribute; the browser retries a dropped connection for GET requests, so network loss is simulated with request aborts in the suite.





5. Security review summary

- ✓ No secrets, API keys, service-role keys or credentials in browser code or public configuration; the generator refuses secret-looking values.
- ✓ The browser stores only a session marker without any credential or customer id; the backend's HttpOnly cookie is the session; tampering with the marker changes nothing.
- ✓ Every customer request is scoped server-side; foreign ids are not found; state changes without the CSRF header are refused; signed file URLs are verified and expire; no permanent document URLs exist.
- ✓ Return paths after sign-in accept only in-site paths; the only HTML injection point is the sanitised legal document; error screens never show internals; sensitive fields never reach diagnostics.
- ✓ Requirements that live outside the repository (HTTPS and Secure cookies, exact-origin CORS with credentials, rate limiting, identity-provider password policy and MFA, private storage with short-lived signed URLs, upload scanning) are listed in `docs/INTEGRATION.md` §9. No certification is claimed.

6. Status of each integration

Integration	Status	Exact input required
-------------	--------	----------------------

Identity provider	Implemented, NOT CONNECTED	A backend exposing the <code>/auth/*</code> routes of the contract, fronting the chosen hosted identity provider; its public settings in <code>AUTH_PUBLIC_CONFIG</code> .
Customer backend API	Implemented, NOT CONNECTED	A backend exposing the <code>/me/*</code> routes with server-side customer scoping; <code>API_BASE_URL</code> .
Document storage	Implemented, NOT CONNECTED	Private storage behind <code>/me/documents*</code> with signed, expiring URLs.
Payment history	Implemented, NOT CONNECTED	The payment layer's history behind <code>/me/payments</code> .
Notification delivery	Implemented, NOT CONNECTED	The notification service behind <code>/me/notifications*</code> ; delivery channels are the backend's.
Terms of Service	Pages and acceptance implemented, NOT CONNECTED	The official text in Arabic and English with version and effective date, via <code>/legal/terms</code> or static files.
Privacy Policy	Pages and acceptance implemented, NOT CONNECTED	As above via <code>/legal/privacy</code> .
Flight supplier (Stage 11)	Development adapter only	A supplier adapter behind a server-side proxy; the supplier's airport registry; fare-rule texts and service fees.
Payment provider (Stage 11)	Development provider only	Hosted fields or redirect plus webhook. No payment processing was changed in 12.1.

7. Business inputs still needed

- Photography, the vector logo master and an official reversed lockup (carried from Stage 10).
- Verified support channels, working hours and the five supervisors' names, photos and profiles.
- The backend and services above, the legal documents, and confirmation delivery by email or SMS.
- Deployment values for `.env.example`, written at deploy time and never committed.

8. Next required actions

1. Provision the backend to the contract in `docs/INTEGRATION.md` §3 and the legal documents; point `API_BASE_URL` and `LEGAL_DOCUMENT_CONFIG` at them through the deploy step.
2. Run `tests/integration.mjs` against the real backend (without the test-only controls) and only then mark the adapters connected in `installed.js`.
3. Connect the flight supplier and payment provider for Stage 11 the same way, one registration each.

4. Stage 13 onward: supervisor dashboard and commissions, admin and operations — none of which were started.